SECURITY OPERATIONS · ADVISORY WHITE PAPER

Human, Script or AI? Spotting AI-Driven Attacks in the SOC

Practical SOC principles for detection, triage, and response.

M. Walker · Independent advisory paper

EVIDENCE CUT 23 Sep 2026 | FRESHNESS SCAN 78 days | REFERENCES 19 | STATUS Final

1 Executive summary

- Where AI is in an intrusion, orchestration has largely displaced assistance. Anthropic reports that a majority of the operations described in its September 2026 threat assessment were enabled by AI through direct execution or orchestration rather than as analytical support, with multi-agent frameworks running for hours or days under limited human oversight.[13] That is a statement about documented AI-misuse cases, not a measure of how common AI involvement is across all intrusions. The operational consequence is still real. Where a SOC judges AI to be in play, the working assumption should now be orchestration rather than a human operator with a good assistant.[13]

- A security operations centre (SOC) remains unlikely to prove from logs alone that an attack is driven by artificial intelligence (AI). Current evidence supports confidence-based assessment, not definitive attribution.[1, 2, 3, 6] That limitation matters less than it did. The more useful question is no longer whether AI is present but what changes if it is.

- AI-driven cyber activity usually reuses familiar tactics, techniques, and procedures (TTPs). The observable difference is more often tempo, adaptation, sequencing, and breadth across telemetry.[1, 2, 3, 7, 12]

- The stronger observable indicators are compressed kill-chain timing, rapid troubleshooting, environment-specific payloads, high command variation, and cross-domain progression.[2, 4, 6] Two publicly disclosed incidents now give several of these indicators observed anchors rather than research-setting estimates.[14, 15] Emerging research methodologies, including defensive prompt injection, command lexical fingerprinting, canary tripping rates, and semantic diversity measurement, may add further signal as they mature. Section 5 summarises these.[8, 9, 10, 11]

- Large language model (LLM) driven activity is not always noisier. Noise is useful context when agents fail, retry, or explore too broadly. It is not a reliable attribution method.[3, 4, 6, 12]

- The practical ceiling today is a confidence score. A SOC can combine the metric indicators in this document with subjective binary factors, for example whether a payload mutated faster than a human plausibly could, into a weighted likelihood rating for suspected AI involvement. No single indicator supports a definitive determination.[1, 2, 6]

- Incident response fundamentals hold. Two distinct pressures now sit on them. The first is decision speed inside an incident, where stage compression puts weight on pre-approved containment, clear authority, and cross-domain correlation.[5] The second is detection durability across incidents. Anthropic describes adversaries able to iterate past a newly deployed detection faster than defenders can build and ship the next one. That is a different problem from containment arriving late, and it is not solved by the same controls.[13] AI and classical machine learning detection techniques are emerging that look promising, and vendor tooling built on these techniques is anticipated within 6 to 12 months.[8, 10, 11] Teams can review the techniques in Section 5 now, and start planning for in-house AI expertise or vendor adoption as these options mature.

2 What changes and what does not

Area	What remains the same	What AI may change
TTPs	Activity still maps to MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) across identity, endpoint, cloud, network, and applications.[2, 7]	Familiar TTPs may be chained faster and with less human delay.[1, 3, 4, 12]
Timing	Reconnaissance, exploitation, foothold, privilege access, and lateral movement still occur.[7]	Time between stages may compress from hours to minutes. One disclosed case moved from a single stolen developer token to full administrative control in roughly three hours.[4, 13]
Payloads	Commands, hypertext transfer protocol (HTTP) parameters, scripts, and binaries remain observable.[7]	Payloads may mutate quickly and incorporate local hostnames, paths, routes, or error responses.[2, 6]

Area	What remains the same	What AI may change
Troubleshooting	Humans, scripts, and tools all fail and retry.[6]	Agents may run short error-correction loops and switch tools quickly. In one observed case they moved from a failed login to a working fix in 31 seconds.[4, 6, 15]
Network traffic interpretation	Scripts and analysts can parse responses and act on them.[1, 5]	Subsequent actions may reflect decoded protocol, API (application programming interface), or error content within seconds.[2, 6]
Detection	Indicator of compromise (IOC) and rule-based detection still matter.[5, 7]	Behavioural scoring and cross-domain correlation carry more weight. Individual atomic indicators are weaker against fast adaptive activity, and more of the signal sits in coherent sequences across telemetry.[1, 2, 5]
Response	Containment, eradication, recovery, evidence handling, and escalation remain core.[5]	Decision speed and delegated authority matter more, because stage compression can outpace conventional approval chains. Detection durability is also affected, because an adversary may iterate past a new detection faster than the next one can be built.[4, 5, 13]

3 SOC observable indicators

The indicators below are largely non-distinct and should be treated as lower-confidence signals. Each overlaps with legitimate automation, testing activity, and skilled human operators. None is sufficient on its own. They are presented as scoring inputs that may raise or lower suspicion when several appear together in one coherent sequence.[1, 3, 6] The combination with speed matters most. High entropy or adaptive behaviour arriving at machine speed weakens both the human-operator explanation and the static-script explanation at once.

Indicator	What the SOC may see	Why it matters	False positives or caveats
Compressed kill-chain timing	Recon, exploit, foothold, and lateral movement in a short window.[4, 7]	AI assistance may reduce human analysis time between stages.[3, 4]	Red teams, automated pen-test tools, wormable malware, and scanners.
Rapid recon to exploitation	New service discovery followed quickly by targeted exploit attempts.[4, 7]	Shows fast interpretation of exposed surface and likely vulnerability context.[2, 4]	Mature scan-to-exploit tooling can look similar.
Fast foothold to lateral movement	Identity use, host discovery, privilege checks, and remote access soon after first access.[2, 7]	Suggests automated decisioning or an operator using strong automation.[1, 2]	Skilled human operators and scripted post-exploitation workflows.
Environment-specific payloads	Payloads include recently observed paths, hostnames, routes, tenant names, cloud metadata, or user details.[2, 6]	Context-aware generation is more suggestive than generic scanning.[2, 6]	DevOps automation, configuration tools, response scripts, and red teams.
High entropy or mutating commands	Many unique commands, parameters, payloads, or short-lived destinations in a narrow window.[2, 6]	Supports anomaly detection where payloads are being generated or adapted rapidly.[5, 6]	Fuzzers, WAF testing, polymorphic malware, CI (continuous integration) pipelines, and scanners.

Indicator	What the SOC may see	Why it matters	False positives or caveats
Repeated troubleshooting loops	Failed commands or blocked requests followed quickly by adjusted syntax, tools, or parameters.[4, 6]	Agents may iterate on errors in seconds to minutes. In one disclosed case an agent moved from a failed login to a corrective payload in 31 seconds, and adapted its parser when a request returned XML where it expected JSON.[4, 6, 15]	Humans fixing mistakes and scripted retry logic, though neither usually turns a diagnosis around inside a minute.
Network-traffic-decoding-dependent behaviour	A next request or command reflects API responses, protocol banners, headers, or error bodies just observed.[2, 6]	Suggests automated parsing and action selection.[2, 6]	SOAR (security orchestration, automation, and response) enrichment, scripted parsers, human analysts, and DLP (data loss prevention) testing.
Adaptive command sequencing	Tool switching, changed flags, or adjusted command order after denial, timeout, or error.[2, 6]	Indicates feedback-driven execution rather than static automation.[2, 6]	Admin troubleshooting and well written automation.
Cross-domain coordination	Endpoint, identity, WAF (web application firewall), proxy, cloud, SaaS (software as a service), and application events chain together faster than normal triage.[1, 2, 5]	Confidence rises when independent telemetry sources show one coherent sequence.[1, 2, 5]	EDR (endpoint detection and response) live response, SOAR playbooks, and authorised automation.

Indicator	What the SOC may see	Why it matters	False positives or caveats
Unusual breadth of exploration	Many hosts, accounts, APIs, repositories, or applications touched in a short period. One disclosed intrusion logged over 17,000 attacker actions across a single weekend, spread over a swarm of short-lived sandbox environments.[2, 4, 14]	AI-assisted workflows may explore broadly while searching for a path forward, and at volumes no human operator sustains.[2, 4, 14]	Vulnerability management, discovery jobs, and broad incident response sweeps, none of which produce a disposable sandbox swarm.

4 Are AI-driven attacks noisier?

Public evidence does not support a universal rule that AI-driven attacks are always noisier than humans or standard automation.[3, 6] They can be noisy when agents fail, retry, produce malformed payloads, explore too broadly, or loop through troubleshooting.[4, 6, 12] They may become quieter as tooling improves, when operators constrain the agent, or when the activity is mostly orchestration of existing tools.[1, 2, 3] Treat noise as a contextual signal. It can increase suspicion when paired with speed, adaptation, and cross-domain sequencing. It is weaker as a standalone AI label.[1, 2, 6]

Volume is worth separating from noise. The Hugging Face intrusion was not subtle, and the sheer count of logged actions was what made reconstruction possible at all. The same case shows that a high action count can coexist with an operation that ran for a weekend before it was stopped.[14] Volume alone did not shorten the detection window.

5 Emerging methodologies for distinguishing AI-driven attacks

Best practice methodologies for distinguishing LLM-driven attacks are not yet firmly established. Even so, numerous promising potential indicators of AI-driven attack are emerging from academic and industry researchers. The more established methodologies in the research literature are summarised below.

These findings are indicative-only. They are not a brief for production deployment. At best, these methodologies provide an ensemble of techniques which could be used to score the

likelihood an attack is LLM-driven, rather than provide a definitive determination.

I suggest these methodologies inform long-term plans for adopting AI and AI-skilled professionals in the SOC.

I anticipate major security vendors will release tooling within 6 to 12 months that applies these same principles.

Defensive prompt injection

Prompt injections embedded within system response payloads or other attacker-visible telemetry are emerging as a technique both to disrupt and fingerprint AI attackers.

One example is the Trace framework. It uses a two-step methodology that includes terminal command fingerprinting (see below) and prompt injection to attempt to extract the attacking agent's system prompt.[8]

Prompt injections are optimised for specific models and model families detected utilising LLMmap, an open-source research tool for prompt-based LLM fingerprinting.[9] Success on a prompt injection can therefore contribute not only to detecting the presence of AI but also to fingerprinting the precise model and instructions the attacker is utilising. The Trace team were able to achieve an average 81.9% system prompt extraction rate using fingerprint-guided prompt injection payloads.[8]

Command lexical fingerprinting

A large volume of research papers and tooling have been produced to detect AI-generated code and identify the associated model family. The Trace team were able to predict with approximately 98% accuracy the attacking model in their simulation by applying classical machine-learning models to attacker terminal commands.[8]

> "For example, DeepSeek chains find with -exec grep. Claude Opus constrains searches with -maxdepth. GPT-5.4 reads files via sed. Such idioms emerge from pretraining corpora and we observed that they persist across different scaffolds."[8]

Fingerprinting work has since extended past the terminal. Research published in 2026 applies the same approach to browser agents using interface interaction traces, a surface this document does not otherwise address and one that a SOC relying only on command telemetry would miss.[17] A 2026 survey of terminal agents gives a broader view of the environment these command idioms emerge from.[18]

Canary tripping

Recent research indicates that LLMs are more than twice as likely as human attackers to fall for honey tokens and other canary resources.[10] More capable models also appear to trip

more canaries.[11] Where historical baseline data is available, the tripping of an unusually high number of canaries may therefore serve as an additional measurable factor in determining the probability an attack is LLM-driven.

This signal may degrade where agents share memory. Later work argues that a honeytoken cannot simultaneously be harmless to trusted agents and remain unrecognisable to an attacker able to pool information across instances, because a coalition probing repeatedly can learn to separate real objects from decoys.[19] That is a theoretical result rather than a measured one, and it does not contradict the higher tripping rates above. It does suggest the signal is most reliable early and against single agents, and least reliable against the kind of coordinated swarm seen in disclosed incidents.[14, 19]

Semantic diversity of high speed and high volume successive commands

LLM agents are unique in their ability to produce contextually-coherent retries with high-semantic-diversity in rapid succession. Each command is a meaningfully different reformulation, adapted to the previous command's output.

This behaviour is distinct from human activity (high semantic entropy, but slow cadence) and from fuzzy script-driven commands (high volume, low semantic entropy or combinatorial mutations).

Exact thresholds for the timings and volume indicative of AI-attack do not exist. Some research attack simulations have centred on an average of 1.7 seconds between local model commands, however this timing is likely longer where frontier APIs are used.[6] A disclosed production incident provides a coarser but real anchor, with a documented 31 seconds between a failed login and a working corrective payload, diagnosis included.[15]

I therefore suggest that the overall volume and lowest latency of high-entropy request clusters (both over short intervals and multi-hour sessions) may serve as an additional useful, but not definitive, metric in rating the likelihood of a sequence of actions as being AI-driven.

6 Detection principles

Behaviour in this document means the combination of measurable execution features described above, such as timing between stages, retry cadence, payload shape and diversity, and sequence coherence across telemetry, rather than any single indicator. These features can serve as weighted inputs to a scoring model for the likelihood of an LLM-driven attacker, alongside subjective binary factors. Most organisations are more likely to receive this capability through vendor tooling than to build it in house.[6, 8, 10, 11]

- Detect behaviour, not AI attribution. Label activity as suspected AI-assisted only with stated confidence.[1, 2, 3, 6]

- Measure time compression between stages, especially recon to exploit and foothold to lateral movement.[4]
- Correlate telemetry across endpoint, identity, network, cloud, WAF, SaaS, application, and SIEM (security information and event management) sources.[1, 2, 5]
- Baseline commands, payload shape, user behaviour, service behaviour, and admin automation windows.[5, 6]
- Alert on rapid adaptive retries, payload mutation, and environment-specific payload generation.[2, 6]
- Use deception controls, honeypots, and canary assets as signal sources, not as proof that an agent is present, and treat their value as strongest against single agents rather than coordinated ones.[6, 19]
- Record the assessment basis, false positives considered, and confidence level in incident notes.[1, 3, 5]

7 Response implications

Incident response fundamentals do not change because suspected AI is involved.[5] Two things about the operating environment do.

The first is tempo inside an incident.[4, 5] SOC and cyber defence teams commonly maintain pre-approved containment paths, documented kill-chains, dependency maps, clear authority for rapid containment, rehearsed playbooks, vendor escalation paths, and SIEM plus XDR (extended detection and response) correlation. These are worth reviewing against compressed timelines.[5] Identity, host, cloud, and application containment are usually considered before broad network containment. Network containment remains available when speed and blast radius justify it. It is not typically treated as the default response.[5]

The second is detection durability across incidents. Faster containment does not address it. Anthropic's assessment is that where defenders could previously slow an attacker by deploying a new detection, a capable adversary may now close that loop and bypass the detection faster than the next one can be developed and deployed.[13] Reported behaviour in the same assessment includes agents modifying malware autonomously when a detection fired and iterating until evasion succeeded.[13] If that pattern holds, the useful measure is not only mean time to contain but how long a newly shipped detection survives contact. Most teams do not currently track that.

A third consideration is practical rather than strategic. In at least one disclosed incident, responders found that commercial model guardrails initially refused to analyse genuine attack artefacts, and fell back to self-hosted models to complete the forensic work.[14] Teams that expect to use AI assistance during response should establish before an incident whether their tooling will process hostile material.

8 Limitations

No reliable public evidence currently proves AI attribution from logs alone.[1, 2, 3, 6] Many indicators overlap with skilled human operators, traditional automation, red team tooling, and security operations activity.[1, 3, 6] In practice, teams generally work from a confidence-based assessment supported by cross-domain telemetry, threat intelligence, observed timing, and clear caveats.[1, 2, 5] An assessment of this kind reflects current common practice rather than a ceiling. Posture can continue to improve as baselines, telemetry coverage, and detection features mature.

The reframing in Section 1 carries its own limitation. The finding that a majority of documented operations were AI-orchestrated describes the set of AI-misuse cases one vendor detected on its own platform.[13] It is not a measure of how often AI appears across intrusions generally. It should not be read as one.

The emerging techniques in Section 5 have so far been demonstrated in research settings and are likely to require additional work before they can be operationalised and supported in day-to-day operations.[8, 10, 11] Organisations pursuing them may need new or expanded capability, though interview research with SOC practitioners suggests the binding constraint is less often specialist headcount than organisational readiness and the management of over-reliance, with adoption proceeding under competitive pressure regardless of assessed feasibility.[16] Alternatively, organisations may prefer to adopt the commercial tooling expected to incorporate these techniques within 6 to 12 months.

9 References

Numbered citations throughout this document refer to the sources below.

1 **Adversarial Misuse of Generative AI.** Google Cloud Threat Intelligence Group, January 2025. https://cloud.google.com/blog/topics/threat-intelligence/adversarial-misuse-generative-ai

2 **What we learned mapping a year's worth of AI-enabled cyber threats.** Anthropic, 3 June 2026. https://www.anthropic.com/news/AI-enabled-cyber-threats-mitre-attack

3 **The near-term impact of AI on the cyber threat.** UK National Cyber Security Centre, January 2024. https://www.ncsc.gov.uk/report/impact-of-ai-on-cyber-threat

4 **Frontier AI Trends Report.** UK AI Security Institute, December 2025. https://www.aisi.gov.uk/frontier-ai-trends-report

5 **NIST SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management.** Nelson, Rekhi, Souppaya, and Scarfone, NIST, 3 April 2025. https://csrc.nist.gov/pubs/sp/800/61/r3/final

6 **LLM Agent Honeypot: Monitoring AI Hacking Agents in the Wild.** Reworr and Volkov, arXiv, 2024, version 2. https://arxiv.org/html/2410.13919v2

7 **MITRE ATT&CK Enterprise Matrix.** MITRE, living resource, accessed 7 July 2026. https://attack.mitre.org/matrices/enterprise/

8 **Trace: Unmasking AI Attack Agents Through Terminal Behavior Fingerprinting.** Ediga and Chattopadhyay, arXiv, 2026. https://arxiv.org/html/2605.01186

9 **LLMmap.** Pasquini et al., GitHub, accessed 7 July 2026. https://github.com/pasquini-dario/LLMmap

10 **Honeyquest for LLMs: Rethinking Cyber Deception for AI Attackers.** arXiv, 2026. https://arxiv.org/abs/2606.21037

11 **AI Agents and Canaries.** Tracebit Research, accessed 7 July 2026. https://agentic.tracebit.com/

12 **Why cyber defenders need to be ready for frontier AI.** UK National Cyber Security Centre, March 2026. https://www.ncsc.gov.uk/blogs/why-cyber-defenders-need-to-be-ready-for-frontier-ai

13 **Detecting and countering misuse of AI: September 2026.** Anthropic, September 2026, covering December 2025 to August 2026. https://www.anthropic.com/threat-intelligence-report-september-2026

Supports the shift from assistance to orchestration, the reported tempo figures, and the detection durability problem.

14 **Hugging Face autonomous agent breach research note.** Cloud Security Alliance, July 2026. https://labs.cloudsecurityalliance.org/research/csa-research-note-huggingface-autonomous-agent-breach-202607/

Supports the 17,000 logged actions figure, the disposable sandbox swarm, and the guardrail obstruction encountered during forensics.

15 **JADEPUFFER: Agentic ransomware for automated database extortion.** Michael Clark, Sysdig, 1 July 2026. https://www.sysdig.com/blog/jadepuffer-agentic-ransomware-for-automated-database-extortion

Supports the timestamped 31 second failed-login to corrective-payload interval and the observed parser adaptation.

16 **From Chasing Ghosts to Missed Attacks: Perspectives and Perceptions of SOC Practitioners on LLM Integration, Risks, and Readiness.** Thurner, Jost, Horstmann, Ising, Groeber, Naiakshina and Schinzel, arXiv 2608.00672, 1 August 2026. https://arxiv.org/abs/2608.00672

Twenty-five practitioner interviews. Supports the readiness and over-reliance framing in Section 8.

17 **Known By Their Actions: Fingerprinting LLM Browser Agents via UI Traces.** arXiv 2605.14786, 2026. https://arxiv.org/abs/2605.14786

Cited for the existence of browser-agent fingerprinting as a distinct surface. Abstract not assessed in depth for this revision.

18 **Terminal Agents: A Survey of AI Agents in Command-Line Environments.** arXiv 2608.20485, August 2026. https://arxiv.org/abs/2608.20485

Cited as a landscape reference for terminal agent behaviour. Abstract not assessed in depth for this revision.

19 **When Agents Talk: Honeytokens under Shared Memory.** arXiv 2608.11436, August 2026. https://arxiv.org/abs/2608.11436

Theoretical result. Supports the decay condition on canary tripping where agents pool information.

Confidence language throughout reflects the public evidence base as at 23 September 2026.

Change record, v3 to v4

Applied after a freshness scan covering 7 July to 23 September 2026. Every change below was approved individually. Nothing else in the document moved.

#	Change	Sections	Evidence
1	Executive summary reframed to lead with orchestration displacing assistance, narrowed to what the source actually claims. Detection durability separated from incident tempo.	1, 2, 7	13
2	Hugging Face breach added as an observed anchor for breadth of exploration. Guardrail obstruction added as a response consideration.	3, 4, 7	14

#	Change	Sections	Evidence
3	JadePuffer added as a timestamped anchor for retry-loop cadence.	2, 3, 5	15
4	Capability constraint amended from specialist headcount to organisational readiness and over-reliance.	8	16
5	Fingerprinting noted as extending past the terminal to browser agents.	5	17, 18
6	Decay condition added to canary tripping where agents share memory.	5, 6	19
-	Limitation added recording that the Section 1 reframe rests on one vendor's platform data.	8	13

Section 5 is unchanged from v3 apart from the two additions above, because it has already been through the voice rewrite as the pilot section.

Confidence language throughout reflects the public evidence base as at 23 September 2026. Every claim carries a numbered citation to a named source. Where a source was not read in full, the reference says so.